

Penetration Test Report

Target: 192.168.56.101/32

Scan Date: April 28, 2026

Overall Risk: **CRITICAL**

Executive Summary

This penetration test was conducted against target system 192.168.56.101 on April 28, 2026. The assessment identified multiple critical security vulnerabilities that pose significant risk to the organization's security posture. The target system, which appears to be running on an outdated Linux distribution with legacy services, exposes eight open network services across the scanned port range (1-200).

The assessment revealed **two Critical-severity vulnerabilities, three High-severity vulnerabilities, two Medium-severity vulnerabilities, and one Low-severity vulnerability**. The most critical findings include a backdoored FTP server (vsftpd 2.3.4) with remote code execution capabilities, and an outdated Samba server (version 3.0.20) that allows unauthenticated remote command execution. Additional high-risk issues include the presence of an unencrypted Telnet service that transmits credentials in cleartext, outdated DNS server software with known security flaws, and a vulnerable Apache web server exposing sensitive administrative interfaces.

The overall risk rating for this system is **CRITICAL**. Immediate remediation is required to address the remote code execution vulnerabilities in vsftpd and Samba, as these could allow an attacker to gain complete control of the system without authentication. The organization should prioritize upgrading all end-of-life software, disabling insecure legacy protocols (Telnet, FTP), and implementing network segmentation to limit exposure of critical services. A detailed action plan with specific remediation steps is provided in the findings section of this report.

Scope and Methodology

The scope of this penetration test was limited to the IP address **192.168.56.101/32** with port scanning restricted to TCP ports 1 through 200. The assessment was conducted using industry-standard reconnaissance and vulnerability identification tools including Nmap (version 7.99) for port scanning and service enumeration with OS detection and default script scanning enabled, Gobuster for web directory enumeration, cURL for HTTP header analysis, and WHOIS for domain registration information gathering. All scanning activities were performed in a non-intrusive manner designed to identify vulnerabilities without disrupting normal system operations.

This assessment was strictly a **black-box reconnaissance and vulnerability identification engagement**. No exploitation of discovered vulnerabilities was performed. The testing did not include any attempts to authenticate to services using default credentials, brute force attacks, social engineering, physical security testing, or wireless network assessment. No files were modified, uploaded, or deleted on the target system. No shellcode or exploit payloads were executed. No denial-of-service attacks were conducted. The findings in this report are based solely on service version identification, banner grabbing, and publicly available vulnerability databases. The actual exploitability of identified vulnerabilities should be confirmed through authorized exploitation testing in a controlled environment if required.

Risk Assessment

Risk Matrix

Severity Level	Count
CRITICAL	2
HIGH	3
MEDIUM	2
LOW	1

Overall Risk Rating

Risk Level: CRITICAL

The overall risk rating is determined by the highest severity vulnerability present in the system. This target has been assigned a CRITICAL risk rating due to the presence of two critical-severity vulnerabilities that allow unauthenticated remote code execution. These vulnerabilities in vsftpd 2.3.4 (CVE-2011-2523) and Samba 3.0.20 (CVE-2007-2447) represent an immediate and severe threat to the confidentiality, integrity, and availability of the system and potentially the entire network. Both vulnerabilities have publicly available exploits and have been widely exploited in real-world attacks. Immediate action is required to remediate these issues before the system can be considered secure for production use.

Detailed Findings

ID	Title	Severity	Evidence	CVE	Remediation
VULN-001	Remote Code Execution – Backdoor	CRITICAL	nmap detected vsftpd 2.3.4 running on port 21/tcp with anonymous FTP login allowed	CVE-2011-2523	Upgrade to vsftpd 2.3.5 or later. Remove the compromised binary. Disable anonymous FTP access.
VULN-002	Weak Cryptographic Algorithms	LOW	nmap detected OpenSSH 4.7p1 Debian 8ubuntu1 on port 22/tcp	CVE-2008-5161	Upgrade to OpenSSH 7.4 or later. Disable weak ciphers and key exchange algorithms in sshd_config.
VULN-003	Cleartext Protocol – Credential Exposure	HIGH	nmap detected Linux telnetd running on port 23/tcp	No CVE	Disable telnet service immediately. Use SSH (port 22) for secure remote access instead.
VULN-004	Weak SSL/TLS Configuration	MEDIUM	nmap script sslv2 detected SSLv2 support on port 25/tcp with export-grade ciphers	No CVE	Disable SSLv2 and SSLv3. Configure TLS 1.2+ only. Disable VRFY and EXPN commands in Postfix configuration.
VULN-005	End-of-Life Software – Multiple Known Vulnerabilities	HIGH	nmap detected ISC BIND 9.4.2 on port 53/tcp via dns-nsid script	No CVE	Upgrade to ISC BIND 9.16 or later (current stable branch). Consider using alternative DNS solutions with active security support.
VULN-006	Denial of Service – Range Header Attack	HIGH	nmap detected Apache httpd 2.2.8 on port 80/tcp; gobuster found phpMyAdmin, phpinfo.php, and WebDAV directory;	CVE-2011-3192	Upgrade Apache to 2.4.x. Upgrade PHP to 7.4 or 8.x. Remove phpinfo.php. Restrict access to phpMyAdmin and

ID	Title	Severity	Evidence	CVE	Remediation
			curl shows X-Powered-By: PHP/5.2.4-2ubuntu5.10		WebDAV. Apply Range header limits.
VULN-007	Information Disclosure – RPC Service Enumeration	MEDIUM	nmap detected rpcbind version 2 on port 111/tcp; rpcinfo script shows NFS, mountd, and nlockmgr services exposed	No CVE	Restrict rpcbind access with firewall rules to trusted networks only. Disable NFS if not required. Use NFSv4 with Kerberos authentication if NFS is necessary.
VULN-008	Remote Code Execution – Username Map Script	CRITICAL	nmap detected Samba smbd 3.0.20-Debian on port 139/tcp; smb-security-mode script shows guest account enabled, message signing disabled	CVE-2007-2447	Upgrade Samba to version 3.0.25 or later (preferably 4.x). Disable guest access. Enable SMB message signing. Disable username map script functionality.

Appendix A: Raw Tool Outputs

Nmap Scan Results

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE nmaprun>
<?xml-stylesheet href="file:///C:/Program Files (x86)/Nmap/nmap.xsl" type="text/xsl"?>
<!-- Nmap 7.99 scan initiated Tue Apr 28 13:41:02 2026 as: nmap -sV -O -sC --open -p 1-200 -oX
- 192.168.56.101 -->
<nmaprun scanner="nmap" args="nmap -sV -O -sC --open -p 1-200 -oX - 192.168.56.101"
start="1777398062" startstr="Tue Apr 28 13:41:02 2026" version="7.99" xmloutputversion="1.05">
<scaninfo type="syn" protocol="tcp" numservices="200" services="1-200"/>
<verbose level="0"/>
<debugging level="0"/>
<hosthint><status state="up" reason="arp-response" reason_ttl="0"/>
<address addr="192.168.56.101" addrtype="ipv4"/>
<address addr="08:00:27:B0:8F:13" addrtype="mac" vendor="Oracle VirtualBox virtual NIC"/>
<hostnames>
</hostnames>
</hosthint>
<host starttime="1777398070" endtime="1777398107"><status state="up" reason="arp-response"
reason_ttl="0"/>
<address addr="192.168.56.101" addrtype="ipv4"/>
<address addr="08:00:27:B0:8F:13" addrtype="mac" vendor="Oracle VirtualBox virtual NIC"/>
<hostnames>
</hostnames>
<ports><extraports state="closed" count="192">
<extrareasons reason="reset" count="192" proto="tcp"
ports="1-20,24,26-52,54-79,81-110,112-138,140-200"/>
</extraports>
<port protocol="tcp" portid="21"><state state="open" reason="syn-ack" reason_ttl="64"/
><service name="ftp" product="vsftpd" version="2.3.4" ostype="Unix" method="probed"
conf="10"><cpe>cpe:/a:vsftpd:vsftpd:2.3.4</cpe></service><script id="ftp-anon"
output="Anonymous FTP login allowed (FTP code 230)"/><script id="ftp-syst" output="
STAT:
FTP server status:
  Connected to 192.168.56.1
  Logged in as ftp
  TYPE: ASCII
  No session bandwidth limit
  Session timeout in seconds is 300
  Control connection is plain text
  Data connections will be plain text
  vsFTPD 2.3.4 - secure, fast, stable
End of status"><elem key="STAT">
FTP server status:
  Connected to 192.168.56.1
  Logged in as ftp
  TYPE: ASCII
  No session bandwidth limit
  Session timeout in seconds is 300
  Control connection is plain text
  Data connections will be plain text
  vsFTPD 2.3.4 - secure, fast, stable
End of status</elem>
</script></port>
<port protocol="tcp" portid="22"><state state="open" reason="syn-ack" reason_ttl="64"/
```

```

><service name="ssh" product="OpenSSH" version="4.7p1 Debian 8ubuntu1" extrainfo="protocol
2.0" ostype="Linux" method="probed" conf="10"><cpe>cpe:/a:openbsd:openssh:4.7p1</
cpe><cpe>cpe:/o:linux:linux_kernel</cpe></service></port>
<port protocol="tcp" portid="23"><state state="open" reason="syn-ack" reason_ttl="64"/
><service name="telnet" product="Linux telnetd" ostype="Linux" method="probed"
conf="10"><cpe>cpe:/o:linux:linux_kernel</cpe></service></port>
<port protocol="tcp" portid="25"><state state="open" reason="syn-ack" reason_ttl="64"/
><service name="smtp" product="Postfix smtpd" hostname=" metasploitable.localdomain"
method="probed" conf="10"><cpe>cpe:/a:postfix:postfix</cpe></service><script id="sslv2"
output="
    SSLv2 supported
    ciphers:
        SSL2_DES_192_EDE3_CBC_WITH_MD5
        SSL2_RC4_128_EXPORT40_WITH_MD5
        SSL2_DES_64_CBC_WITH_MD5
        SSL2_RC2_128_CBC_WITH_MD5
        SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
        SSL2_RC4_128_WITH_MD5"></script></port>
<port protocol="tcp" portid="53"><state state="open" reason="syn-ack" reason_ttl="64"/
><service name="domain" product="ISC BIND" version="9.4.2" method="probed"
conf="10"><cpe>cpe:/a:isc:bind:9.4.2</cpe></service><script id="dns-nsid" output="
    bind.version: 9.4.2"><elem key="bind.version">9.4.2</elem>
</script></port>
<port protocol="tcp" portid="80"><state state="open" reason="syn-ack" reason_ttl="64"/
><service name="http" product="Apache httpd" version="2.2.8" extrainfo="(Ubuntu) DAV/2"
method="probed" conf="10"><cpe>cpe:/a:apache:http_server:2.2.8</cpe></service><script
id="http-server-header" output="Apache/2.2.8 (Ubuntu) DAV/2"><elem>Apache/2.2.8 (Ubuntu) DAV/
2</elem>
</script><script id="http-title" output="Metasploitable2 - Linux"><elem
key="title">Metasploitable2 - Linux</elem>
</script></port>
<port protocol="tcp" portid="111"><state state="open" reason="syn-ack" reason_ttl="64"/
><service name="rpcbind" version="2" extrainfo="RPC #100000" method="probed" conf="10"/
><script id="rpcinfo" output="
    program version    port/proto  service
    100000  2                111/tcp    rpcbind
    100000  2                111/udp    rpcbind
    100003  2,3,4            2049/tcp   nfs
    100003  2,3,4            2049/udp   nfs
    100005  1,2,3            47103/tcp  mountd
    100005  1,2,3            49230/udp  mountd
    100021  1,3,4            33435/udp  nlockmgr
    100021  1,3,4            54556/tcp  nlockmgr
    100024  1                42663/udp  status
    100024  1                47369/tcp  status
"></script></port>
<port protocol="tcp" portid="139"><state state="open" reason="syn-ack" reason_ttl="64"/
><service name="netbios-ssn" product="Samba smbd" version="3.0.20-Debian"
extrainfo="workgroup: WORKGROUP" method="probed" conf="10"><cpe>cpe:/a:samba:samba</cpe></
service></port>
</ports>
<os><portused state="open" proto="tcp" portid="21"/>
<portused state="closed" proto="tcp" portid="1"/>
<portused state="closed" proto="udp" portid="31505"/>
<osmatch name="Linux 2.6.9 - 2.6.33" accuracy="100" line="63177">
<osclass type="general purpose" vendor="Linux" osfamily="Linux" osgen="2.6.X"
accuracy="100"><cpe>cpe:/o:linux:linux_kernel:2.6</cpe></osclass>
</osmatch>
</os>
<hostscript><script id="smb-security-mode" output="

```

```
account_used: guest
authentication_level: user
challenge_response: supported
message_signing: disabled (dangerous, but default)"><elem key="account_used">guest</elem>
<elem key="authentication_level">user</elem>
<elem key="challenge_response">supported</elem>
<elem key="message_signing">disabled</elem>
</script></hostscript>
<runstats><finished time="1777398107" timestr="Tue Apr 28 13:41:47 2026" summary="Nmap done at
Tue Apr 28 13:41:47 2026; 1 IP address (1 host up) scanned in 45.82 seconds" elapsed="45.82"
exit="success"/><hosts up="1" down="0" total="1"/>
</runstats>
</nmaprun>
```

Gobuster Directory Enumeration

.htpasswd	(Status: 403) [Size: 296]
.hta	(Status: 403) [Size: 291]
.htaccess	(Status: 403) [Size: 296]
cgi-bin/	(Status: 403) [Size: 295]
dav	(Status: 301) [Size: 319] [--> http://192.168.56.101/dav/]
index	(Status: 200) [Size: 891]
index.php	(Status: 200) [Size: 891]
phpMyAdmin	(Status: 301) [Size: 326] [--> http://192.168.56.101/phpMyAdmin/]
phpinfo.php	(Status: 200) [Size: 48029]
phpinfo	(Status: 200) [Size: 48017]
server-status	(Status: 403) [Size: 300]
test	(Status: 301) [Size: 320] [--> http://192.168.56.101/test/]
twiki	(Status: 301) [Size: 321] [--> http://192.168.56.101/twiki/]

cURL HTTP Header Analysis

```
HTTP/1.1 200 OK
Date: Tue, 28 Apr 2026 17:42:02 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Content-Type: text/html
```

WHOIS Lookup

No WHOIS data available for this IP address.

End of Report

This report is confidential and intended solely for the use of the organization to which it is addressed.